

RESERVE BANK OF INDIA
DEPARTMENT OF CYBER SECURITY AND INFORMATION TECHNOLOGY
CENTRAL OFFICE, MUMBAI

Circular No: RBI/2024-25/19 - DoS.CO.CSITE.No.03/11.01.005/2024-25

Date: March 12, 2024

Subject: Master Direction on Cyber Resilience and Digital Payment Security Controls

1. Mandatory Two-Factor Authentication (2FA)

All regulated payment system operators and scheduled commercial banks must enforce dynamic two-factor authentication for all digital transactions.

2. Incident Reporting Timelines (6-Hour Rule)

Any cyber security incident, ransomware compromise, unauthorized system intrusion, or major denial of service must be reported to the RBI within 6 hours of detection.

3. Security Operations Centre (SOC) Operations

Banks must operate a 24x7x365 Security Operations Centre (SOC) equipped with continuous automated log monitoring and incident response capabilities.

4. API Security and Third-Party Risk Management

(a) All open banking and fintech integrations must mandate TLS 1.3 encryption with certificate pinning.

(b) Third-party service providers and cloud vendors must undergo mandatory annual vulnerability assessment and penetration testing.

5. Audit Trail and Forensic Preservation

All critical access logs, privileged user operations, database queries, and perimeter firewall event records must be retained for a minimum of 18 months in an immutable format.

6. Supervisory Penalties

Non-compliance with the cyber resilience directives will invite punitive supervisory action under Section 47A of the Banking Regulation Act, 1949.

Chief General Manager (Information Technology)

Reserve Bank of India